

Assignment #1 – Planning the usage of cryptography in a scenario

OBJECTIVE:

1. Identify the cryptographic mechanisms to secure data at transit in services.
2. Identify the cryptographic mechanisms to secure data at rest in services.
3. Identify robust solutions for encryption, that are future proof (beyond 2030).
4. Perform the identification of a CBOM – Cryptographic Bill of Materials.

CONTEXT:

You are responsible to implement the security of a scenario, and your role is mainly to plan and implement the cryptographic solutions.

The scenario includes in a generic perspective, different services, as pictured in Figure 1.

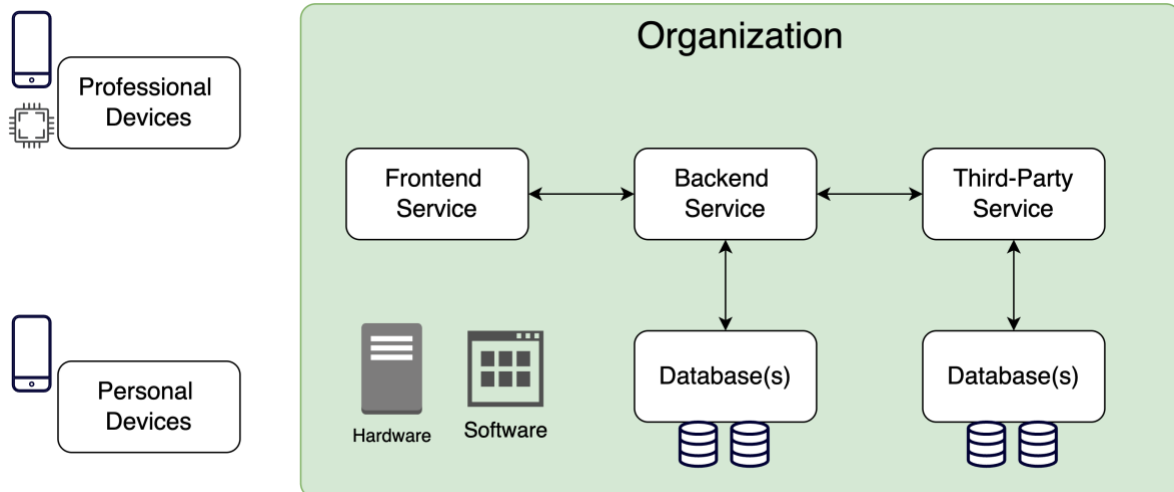


Figure 1 - Generic scenario overview

The scenario considers different types of components:

- **Hardware**, which may include specific components for robust encryption. Examples may include, Hardware Security Modules (HSM), Trust Platform Module (TPM), among others.
- **Software**, which correspond to the implementation of the different services, which can include JAVA, Python or others.

The scenario includes, a minimal of three services:

- **Frontend**, service that interacts with the professional and personal devices to access the functionalities of the platform
- **Backend**, service that interacts with the remaining services:
 - Frontend to receive the requests of clients, devices aiming to access the platform. The backend will ensure that the requests are authenticated, authorized and accounted. The backend also implements the business policies (e.g., change of credentials after a certain time) and interacts with the databases for the CRUD (Create, Read, Update Delete) operations.
 - Third-Party service is used according to the established policies. For instance, the user needs to be authenticated in a 3rd party service, or needs to gather data from a weather API, news API (just to mention some examples).
- **Third-Party** is related with other services like IAM (Identity and Access Management), Photovoltaic (PV) energy generation, weather API, news API, among others that are required for the overall platform.
- **Database** Service, which can be SQL based on non-SQL. **This service is mandatory in the exercise to store data.**

Cryptographic Bill of Materials (CBOM)

CBOM is a proposal to determine accurate usage of Cryptography. CBOM includes among other aspects the following (as per OWASP in the [authoritative guide](#)):

- Cryptographic assets (e.g., algorithms used, key strength, robustness of algorithms)
- Dependencies of cryptographic assets (e.g., in a library implementation dependency from others)
- An object format (JSON, or others) to model cryptographic assets.

CBOM is for cryptography what SBOM (Software Bill of Materials) is for software.

Assignment:

The assignment includes different tasks, including the choice of services and related technologies, a characterization of the CBOM, and the preparation of the assignment 2, where **at least two services + Database** will be instantiated according to the plan.

1. PLAN THE SERVICES

The services need to use specific technologies. Table 1 provides a very simple example, you are free to choose other technologies.

Table 1 - Example of services

Service	Example of technologies
Frontend	Node.JS REST APIs with support for JSON HTTP(S)/3, HTTP(S)/2
Backend	Node.JS REST APIs with support for JSON HTTP(S)/3, HTTP(S)/2
Database	PostgreSQL 9 Redis (NoSQL)
Third-Party	Keycloak for IAM (using OpenID Connect)

You need to:

- Formulate a plan to enable the instantiation of services.
- Describe the data flows at the different interfaces of the services, consider some fields required for basic functionalities like authentication, authorization.
- Identify the virtualization technologies (containers, Virtual Machines).
- Identify the required hardware, for instance will TPM, HSM or other hardware security components be required.
- A hypothetical domain to use for the certificates required by the diverse services.

2. CBOM

Identify the cryptographic solutions (algorithms, protocols) that will be used, along with the cryptographic solutions identify possible libraries. Table 2 provides a very simple example, you need to complete this list.

Table 2 - Example of cryptographic assets

Cryptographic Asset	Description
Certificates X.509	Certificates required for the different services
OpenSSL	Support library to generate certificates and doing internal testing
AES	Algorithm to use for symmetric encryption
HMAC	Hash algorithm to ensure integrity of data (configuration files)
ML-KEM	Algorithm for Key Encapsulation Methods
...	

You need to:

- a. Detail the CBOM, which cryptographic algorithms are you going to use, and why.
- b. You are advised to use automated tools¹, considering possible libraries or websites available and the technological solutions you have chosen.

¹ There are several tools that can be used for CBOMs. Some examples include:

- CBOMkit ([link](#))
- Cdxgen ([link](#))

REPORT (WHAT TO DELIVER):

The report should contain information regarding the options you have made.

For instance:

- a. Why are you choosing a specific technology for the services?
- b. Does this technology support encryption? What are the possible libraries that can be used? Imagining you are implementing in Node.JS, what are the libraries that exist to perform encryption?
- c. Do the solutions support Post Quantum Cryptography?

The report should include also:

- d. Possible addressing and naming scheme to use for the implementation! Remember assignment 2 will correspond to the implementation of **at least two + Database** services.
- e. Clear identification of possible hardware components that could secure the encryption assets (you do not need to implement them in assignment 2).
- f. Regarding the CBOM usually is delivered in a specific format (JSON or other). You need to deliver the file(s) with CBOM information, and the tools required to process/view it.

Plan your work to be delivered on 2025-10-19.